

IT3070 - Information Assurance & Security

Information Security Risk Management Assignment

	IT Number	Name with initials	Batch ID	Contact No	Email
1	IT23579736	Wijethunga P.V.N.M.	WE-IT-2.1	071-4065265	it23579736@my.sliit.lk
2	IT23702172	Soysa W.C.R	WE-IT-4.1	077-3121604	it23702172@my.sliit.lk
3	IT23824942	M M W M Marasingha	WD-IT-2.1	076-7829734	it23824942@my.sliit.lk

Table of Contents

Introduction 3

Assets 3

Employee Information System(IT23579736) 4

Allegro Worksheet 8 5

Allegro Worksheet 10 - 1 8

Allegro Worksheet 10 – 2 12

Hospital Billing & Payment Information (IT23702172) 16

Allegro Worksheet 8 17

Allegro Worksheet 10 -1 19

Allegro Worksheet 10 -2 22

Patient Medical Records (IT23824942) 26

Allegro Worksheet 8 28

Allegro Worksheet 10 -1 31

Introduction

MediCare Plus Private Hospital (Pvt) Ltd

MediCare Plus Private Hospital is a medium sized private hospital in Sri Lanka offering services to patients such as Out Patient Department, Emergency, Lab, Pharmacy, Surgical and In Patient Hospital services. The hospital is employing a computer based Hospital Management System (HMS) to aid its operations and to handle critical information. This includes patient medical records, billing and payment information, employee information, and other healthcare related data. Accurate and readily available patient information is used by doctors and nurses when providing treatment; and billing and employee information are used by the finance and administration department when performing financial and administration activities. Hence, the confidentiality, integrity and availability of information is crucial to the hospital. In the event of unauthorized access, incorrect modification, or inaccessibility of critical information, it may impact patient care, financial operations, employee management and overall hospital functioning.

Assets

Selected Asset	**Name**	**IT Number**
Employee Information System	Wijethunga P.V.N.M.	IT23579736
Hospital Billing & Payment Information	Soysa W.C.R	IT23702172
Patient Medical Records	M M W M Marasingha	IT23824942

Group Leader's Batch and Lab Group

Y3.S2.WE.IT.0201

Employee Information System(IT23579736)

Allegro worksheet 8

Allegro Worksheet 8	CRITICAL INFORMATION ASSET PROFILE	
(1) Critical Asset *What is the critical information asset?*	**(2) Rationale for Selection** *Why is this information asset important to the organization?*	**(3) Description** *What is the agreed-upon description of this information asset?*
Employee Information System (EIS)	The Employee Information System is essential to the implementation of MediCare Plus Private Hospital as the Human Resources department has to rely on correct and reliable employee information to manage the staff of the hospital and have to carry out vital administrative functions. Information is utilized for employee administration, salary administration, attendance administration, leave administration, and employment record. If employees' personal and salary-related information is disclosed to others without their permission, it may lead to violation of their privacy and expose their information. Unauthorized changes may lead to inaccurate salary, attendance, leave, and/or employment records which could lead to financial and administrative issues. In the event of the system becoming unavailable important HR activities may be postponed or hampered. Thus, confidentiality, integrity, and availability of the EIS is essential to the hospital's administrative activities and employees' trust.	The Employee Information System is a computer based information system that is used to store, process and manage the information about the employee of MediCare Plus Private Hospital. The EIS includes details of employees' personal data, employee ID numbers, job roles, departmental information, salary information, attendance information, leave information, and employment information. This system is accessed mainly by authorized HR staff and any other authorized hospital administrators based on their job duties. Human Resource staff uses this information to process employee records, attendance and leave, salary administration and other employee related administrative tasks. The EIS should be able to give controlled access to employee information, depending on the role and responsibility of the user. Staff should be accurately recorded and only sensitive information changed by authorised staff and recorded accordingly in the staff's records for accountability.
(4) Owner(s) *Who owns this information asset?*		
Human Resources (HR) Department, MediCare Plus Private Hospital		

(5) Security Requirements *What are the security requirements for this information asset?*		
❑ **Confidentiality**	Only authorized personnel can view this information asset, as follows:	Employee details should be available to only specific human resource staff and other hospital staff that need to have specific information to fulfil their job. The information regarding the employees, including personal details, salary information, attendance records, leave records, employment records etc., should not be accessible to any unauthorized employees or third parties.
❑ **Integrity**	Only authorized personnel can modify this information asset, as follows:	Employee records should be created, updated and modified by only those authorized by HR to do so based on their role. Authorities should be obtained and recorded when changing information about sensitive information, including salary, attendance, leave, job position, and employment records. The system should keep accurate and complete records of the employees and unauthorized changes, deletion, or manipulation of the data should be prevented and be traceable through appropriate access controls and activity logging.
❑ **Availability**	This asset must be available for these personnel to do their jobs, as follows:	The EIS should be accessible to relevant HR professionals and authorized hospital management when necessary to carry out necessary work in HR and administrative processes such as attendance and leave management, salary administration, etc. Downtime may result in HR operations getting interrupted and may not allow access for authorized personnel to the employee information. Hence an appropriate backup and recovery plan and system availability should be prepared to ensure minimum disruption.

	This asset must be available for _____ hours, _____ days/week, _____ weeks/year.	This asset must be available for 12 hours, 6 days/week, 52 weeks/year.
❑ **Other**	This asset has special regulatory compliance protection requirements, as follows:	The Employee Information System has to be operated in compliance with the relevant legislative, regulatory and organizational policies and procedures of Sri Lanka that govern the protection and proper management of personal and employment data. Employee information should be accessed only for legitimate business reasons and reasonable steps should be taken to secure the information, ensure privacy and maintain accountability.

(6) Most Important Security Requirement

What is the most important security requirement for this information asset?

❑ Confidentiality	❑ Integrity	❑ Availability	❑ Other

The reason that confidentiality is chosen as the most important security requirement is that the EIS includes sensitive employee data such as personal, salary, attendance, leave, and employment records. Unauthorized disclosure could be a breach of employee privacy, a risk of sensitive information and a decrease in employee trust in the hospital. Integrity and availability are also significant, but the most critical security need is to prevent unauthorized access to employee information.

Employee Information System(IT23579736)

Allegro worksheet 10 – Risk 1

Allegro - Worksheet 10		INFORMATION ASSET RISK WORKSHEET			
Information Asset Risk	Information Asset	Employee Information System (EIS)			
	Area of Concern	Unauthorized access to employee information through compromised HR user credentials			
	Threat 1	(1) Actor *Who would exploit the area of concern or threat?*	External attacker / cybercriminal		
		(2) Means *How would the actor do it? What would they do?*	The attacker might be able to get the logins of an authorized HR employee via phishing, credential stealing, or use of an existing stolen password. The attacker could then access the Employee Information System with the stolen identity to obtain employee information such as personal information, salary information, attendance, leave, employment or other information.		
		(3) Motive *What is the actor's reason for doing it?*	The attacker might try to acquire confidential employee data to obtain money, identity theft, to use it for unauthorized disclosure or to sell it to other people.		
		(4) Outcome *What would be the resulting effect on the information asset?*	❑ **Disclosure** ❑ **Destruction** ❑ **Modification** ❑ **Interruption**		
		(5) Security Requirements *How would the information asset's security requirements be breached?*	Confidentiality would be compromised as an outsider with access to the employee's credentials could have access to the sensitive data. These may reveal employee personal information, salary information, attendance information, leave records, and employment records to an unauthorized individual.		
		(6) Probability *What is the likelihood that this threat scenario could occur?*	❑ **High**	❑ **Medium**	❑ **Low**

	(7) Consequences *What are the consequences to the organization or the information asset owner as a result of the outcome and breach of security requirements?*	(8) Severity *How severe are these consequences to the organization or asset owner by impact area?*		
		Impact Area	**Value**	**Score**
	An attacker may gain access to the EIS using stolen HR credentials and access to confidential employee data may be gained. The event may be a violation of the employees' privacy, may provide an opportunity for employee identity theft and may decrease employee trust in the hospital's ability to ensure personal information security. The hospital may also have to conduct a review and investigation of the event, inform relevant parties as appropriate, update accounts security and audit hospital access control protocols. Since the compromised account may have more permissions, it could also give the attacker opportunities to carry out unauthorized actions within the system.	Reputation & Customer Confidence	8	4.0
		Financial	6	3.0
		Productivity	5	2.5
		Safety & Health	1	0.5
		Fines & Legal Penalties	7	3.5
		User Defined Impact Area	9	4.5
			Relative Risk Score	18.0

(9) Risk Mitigation

Based on the total score for this risk, what action will you take?

❑ **Accept**	❑ **Defer**	❑ **Mitigate**	❑ **Transfer**

For the risks that you decide to mitigate, perform the following:

On what container would you apply controls?	*What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?*
User Access Management	**Administrative** - Develop an employee-information access policy regarding who can have access to EIS information. Review the access rights to HR user accounts and privileges regularly and deactivate access rights when an employee changes role or when an employee leaves the hospital.

	Residual Risk - Even if compromised, an account can continue to be used before they are noticed or turned off.
Authentication & EIS Access	**Technical** - Enforce multi factor authentication (MFA) for all EIS users, strong password policies, role based access control (RBAC) and least privilege, and monitor for unusual logon attempts. **Residual Risk** - Some preventive controls may prove to be ineffective if the attack is sophisticated credential theft, or an authenticated session is compromised.
HR/Server Environment	**Physical** - Ensure that physical access to computers and server infrastructure is limited which can be used to operate the EIS. Utilize secured work spaces, device screen locking and controlled access to server rooms if applicable. **Residual Risk** - There are physical security controls that can be used to make it difficult, but not impossible, for an authorized user to misuse an account or information.

Probability Justification

Probability level	Estimated Probability	Justification
Medium	50%	A medium probability of 50% is used because credentials based attacks like phishing and password compromise are realistic threats to systems that have sensitive employee data. However, for this scenario to be true, the attacker must be able to gain access to the hospital without the help of existing authentication and access control systems, and to obtain valid credentials as well. So, it is presumed as a medium risk rather than a high risk.

Impact Justification

Impact area	Rating	Justification
Reputation & Employee Confidence	8	Personal information for employees could cause loss of employee confidence in the hospital's information-security policies and impact the hospital's reputation as an employer.
Financial	6	The hospital's incident investigation, system recovery and security enhancements costs and any ramifications of an employee using the information that was exposed for misuse.
Productivity	5	The normal flow of HR operations may be interrupted, compromised accounts may be investigated, security access may be reviewed and systems may be secured in the meantime.
Safety & Health	1	The EIS is largely used to support HR and administration and not directly in clinical treatment. Thus, direct consequences of a breach in the confidentiality of the EIS for patient safety and health would be minimal.
Fines & Legal Penalties	7	Breach of security of personal information can have legal or regulatory implications as per the conditions and the requirements.
Employee Privacy & HR Operations	9	This is the most affected area as the EIS carries sensitive employee information such as personal information, salary-related information and so on. Unauthorized disclosure may have a great impact on employee privacy and HR work.

Employee Information System(IT23579736)

Allegro worksheet 10 – Risk 2

Allegro - Worksheet 10		INFORMATION ASSET RISK WORKSHEET	
Information Asset Risk	Threat 2	Information Asset	Employee Information System (EIS)
		Area of Concern	Unauthorized modification of employee records by an authorized HR employee
		(1) Actor *Who would exploit the area of concern or threat?*	Authorized HR employee / insider
		(2) Means *How would the actor do it? What would they do?*	An employee might intentionally alter employee records without proper authorization using his or her legitimate access. For instance, the employee could change information about salary, attendance, leave, job placement, or employment information. With adequate privileges, the employee could try to change without the usual approval process of the hospital.
		(3) Motive *What is the actor's reason for doing it?*	They may have had a personal gain, favoritism, they may have been retaliating against another employee, or may have been using this for their own good.
		(4) Outcome *What would be the resulting effect on the information asset?*	❑ **Disclosure** ❑ **Destruction** ❑ **Modification** ❑ **Interruption**
		(5) Security Requirements *How would the information asset's security requirements be breached?*	An authorized employee would be able to make unauthorized and inappropriate changes to employee records, which would compromise the integrity of the records. Inaccurate information about staff pay, attendance, leaves, job position or employment would then be recorded in the EIS and could be utilized for follow-up HR associated errands.

(6) Probability *What is the likelihood that this threat scenario could occur?*	❑ **High**	❑ **Medium**	❑ **Low**

(7) Consequences *What are the consequences to the organization or the information asset owner as a result of the outcome and breach of security requirements?*	(8) Severity *How severe are these consequences to the organization or asset owner by impact area?*		
	Impact Area	**Value**	**Score**
Entry of employee data inaccurately may have a negative effect on the salary calculations, on the accuracy of attendance or leave data, on the accuracy of employment data or on disputes between employees and the hospital. HR staff will be required to do investigation and rectification of impacted records, which can be a burden on HR administration. If changes are not identified in a timely fashion, the wrong information may be incorporated into HR decisions, such as payroll. There is also the risk that if the HR processes are manipulated intentionally, employees may lose faith in the hospital's fairness and reliability.	Reputation & Customer Confidence	7	1.75
	Financial	8	2.00
	Productivity	7	1.75
	Safety & Health	1	0.25
	Fines & Legal Penalties	6	1.50
	User Defined Impact Area	9	2.25
		Relative Risk Score	9.50

(9) Risk Mitigation

Based on the total score for this risk, what action will you take?

❑ **Accept**	❑ **Defer**	❑ **Mitigate**	❑ **Transfer**

For the risks that you decide to mitigate, perform the following:

On what container would you apply controls?	*What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?*
HR Access Management	**Administrative** - Ensure the HR only has access to what they need to do their job. Set up processes for key changes, like pay and employment status changes. Periodically review user privileges.

	Residual Risk - A user, with proper access to the system, could still misuse his/her rights or even coordinate with another employee.
EIS Application & Database	**Technical** - Ensure that records of the changes to employee records are maintained including the name of the user, time and type of change. Alert on unusual and/or high-risk changes and ask for extra permission for sensitive changes. Make frequent backups in order to have data available for accurate recovery in case of unwanted modifications. **Residual Risk** - A sophisticated or coordinated insider action may not be noticed right away, or even all of the changes may be incorrect, which might not become noticeable until reviewed.
HR Work Area	**Physical** - Limit access to HR work areas and computers that are used to process sensitive employee data. Lock screens automatically when not in use and don't allow unauthorized users access to HR work stations. **Residual Risk** - The use of risk-Physical controls cannot guarantee that if authorized users have legitimate access to the HR work area, they will not misuse it in some way.

Probability Justification

Probability level	Estimated Probability	Justification
Low	25%	A 25% probability is assigned because the scenario has to be "deliberately" performed by an authorized employee, who has to carry out an unauthorized modification successfully. Proper access controls, approvals, activity tracking and periodic audits can minimise the risk of successful misuse. But the risk is not fully removed for there are authorized persons who have legitimate access to the system.

Impact Justification

Impact area	Rating	Justification
Reputation & Employee Confidence	7	The handling of employee records might erode employee trust in the fairness, accuracy and security of the hospital's HR practices, especially if it becomes public among employees.
Financial	8	Incorrect salary and/or other employment information changes may lead to incorrect payments, financial discrepancies, further expenses on administration and potential recovery expenses.
Productivity	7	HR staff may be required to search for impacted records and delve into the changes, update inaccurate information, and audit other records, which will create more administration.
Safety & Health	1	The EIS is mainly used for HR and administrative information, and would not be likely to have a direct impact on patient safety or treatment.
Fines & Legal Penalties	6	The hospital may have legal or regulatory issues related to the way information is handled and how it is accessed by employees as a result of the unapproved changes.
Employee Privacy & HR Operations	9	The EIS plays an active part in HR operations. There may be serious consequences for incorrect or manipulated employee records in regards to salary, attendance, leave, employment records and employee privacy.

References

[1] R. Ross and V. Pillitteri, *Security and Privacy Controls for Information Systems and Organizations*, NIST Special Publication 800-53 Rev. 5, National Institute of Standards and Technology, 2020.

https://www.nist.gov/publications/security-and-privacy-controls-information-systems-and-organizations-0

[2] National Institute of Standards and Technology, "Least privilege," *Computer Security Resource Center (CSRC) Glossary*.

https://csrc.nist.gov/glossary/term/least_privilege

[3] R. Ross and V. Pillitteri, *Assessing Security and Privacy Controls in Information Systems and Organizations*, NIST Special Publication 800-53A Rev. 5, 2022.
https://csrc.nist.gov/pubs/sp/800/53/a/r5/final

Hospital Billing & Payment Information (IT23702172)

Allegro worksheet 8

Allegro Worksheet 8	CRITICAL INFORMATION ASSET PROFILE	
(1) Critical Asset *What is the critical information asset?*	**(2) Rationale for Selection** *Why is this information asset important to the organization?*	**(3) Description** *What is the agreed-upon description of this information asset?*
Billing & Payment Information (BPI)	Billing and payment information is important because the hospital needs it to generate patient bills, record payments, manage insurance payments, process refunds, and track outstanding balances. Accurate billing information is also required for hospital financial activities.	Billing and Payments information contains financial information about patients and hospital services. It includes patient invoices, treatment charges, payment records, insurance information, unpaid balances, refund information, and transaction records. The hospital uses this information for payment and financial management purposes.
(4) Owner(s) *Who owns this information asset?*		
Finance and Billing Department		
(5) Security Requirements *What are the security requirements for this information asset?*		
❑ **Confidentiality**	Only authorized personnel can view this information asset, as follows:	Patient billing and payment information should only be available to those with proper authorization from the hospital. Unauthorized people should not have access to sensitive financial and payment details.
❑ **Integrity**	Only authorized personnel can modify this information asset, as follows:	Billing and payment information should only be changed by authorized staff. Electronic records such as bills, payment records, refunds, and transaction history should be accurate and should not be manipulated without permission.
❑ **Availability**	This asset must be available for these personnel to do their jobs, as follows:	Authorized staff must be able to access billing and payment information when they need to generate invoices, check payments, process refunds, or complete other financial transactions.

	This asset must be available for __24___ hours, ___7__ days/week, ___52__ weeks/year.	The information should be accessible whenever authorized hospital staff members are required to do billing and payment processing.
❑ **Other**	This asset has special regulatory compliance protection requirements, as follows:	The hospital should protect patients' financial and payment information according to relevant data protection and payment security requirements. This information should be available only to authorized personnel, and changes should be logged for verification purposes.

(6) Most Important Security Requirement

What is the most important security requirement for this information asset?

❑ Confidentiality	❑ Integrity	❑ Availability	❑ Other

Integrity is the most important security requirement because billing and payment information must be kept accurate. Unauthorized changes may cause incorrect patient charges, incorrect payment records and financial losses to the hospital.

Hospital Billing & Payment Information (IT23702172)

Allegro worksheet 10 – Risk 1

Allegro - Worksheet 10		INFORMATION ASSET RISK WORKSHEET		
Information Asset Risk	Threat 1	Information Asset	Billing & Payment Information (BPI)	
		Area of Concern	*An unauthorized person may get the login details of a hospital billing staff member and use them to access patient billing and payment information.*	
		(1) Actor *Who would exploit the area of concern or threat?*	External attacker / Cybercriminal	
		(2) Means *How would the actor do it? What would they do?*	The attacker may try to send an email or a fake login screen to a hospital staff member. If the staff member enters his/her username and password, the attacker can steal the login information and log on to the billing system.	
		(3) Motive *What is the actor's reason for doing it?*	The attacker's main motive may be financial gain or stealing sensitive patient financial information.	
		(4) Outcome *What would be the resulting effect on the information asset?*	❑ **Disclosure** ❑ **Destruction** ❑ **Modification** ❑ **Interruption**	
			Disclosure: Because someone who should not see the information is able to see it.	
		(5) Security Requirements *How would the information asset's security requirements be breached?*	Confidentiality would be violated because an unauthorized third party could view patient billing, payment, insurance, and transaction information.	
		(6) Probability *What is the likelihood that this threat scenario could occur?*	❑ **High** ❑ **Medium** ❑ **Low**	
			Medium – 50%: There is a medium risk that staff will get fake emails or fake login messages. But the risk of unauthorized access can be minimized through security measures such as strong passwords,	

		employee awareness, and multi-factor authentication

(7) Consequences *What are the consequences to the organization or the information asset owner as a result of the outcome and breach of security requirements?*	(8) Severity *How severe are these consequences to the organization or asset owner by impact area?* *Assuming :* *0= No impact* *10=Highest impact*		
	Impact Area	**Value**	**Score**
Patient billing and payment information could be exposed to an unauthorized person. Patients may lose trust in the hospital. The hospital may also face complaints, financial losses, and costs related to investigating the incident.	Reputation & Customer Confidence	8	4.0
	Financial	7	3.5
	Productivity	5	2.5
	Safety & Health	2	1.0
	Fines & Legal Penalties	6	3.0
	User Defined Impact Area	8	4.0
		Relative Risk Score	**18.0**

(9) Risk Mitigation

Based on the total score for this risk, what action will you take?

❑ **Accept**	❑ **Defer**	❑ **Mitigate**	❑ **Transfer**

Mitigate: Because the hospital can introduce controls to reduce the chance of unauthorized access.

For the risks that you decide to mitigate, perform the following:

On what container would you apply controls?	*What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?*
1. Staff User Accounts	Protect with strong passwords and multi-factor authentication. This decreases the risk of attackers logging into the account using stolen login details. **Residual risk**: Access may still be possible if both the password and second authentication method are compromised.

2. Hospital Employees	Provide staff with security training on fake emails, fake links, and fake login pages. **Residual risk:** Staff might still make mistakes and click a believable phishing link.
3. Billing System	Only grant access to authorized staff based on their job role. **Residual risk:** If an authorized account is stolen or shared, there is still the risk that it will be misused.
4. Billing System	Maintain log files for login and access. **Residual risk:** The attacker may access some information before the unusual activity is detected.
5. Finance Office Computers	Use automatic lock and logout screens when a computer is inactive. **Residual risk:** If the device is already unlocked, then an attacker can also get access.
6. Finance Office / Physical Area	Limit access to computers in the finance office and do not allow unauthorized people to use them. **Residual risk:** Someone may be still able to access the area if access rules are not properly followed.

Hospital Billing & Payment Information (IT23702172)

Allegro worksheet 10 – Risk 2

Allegro - Worksheet 10		INFORMATION ASSET RISK WORKSHEET		
Information Asset Risk	Threat 2	Information Asset	Billing & Payment Information (BPI)	
		Area of Concern	*An unauthorized hospital employee may misuse their access and change patient billing or payment records without permission.*	
		(1) Actor *Who would exploit the area of concern or threat?*	Authorized Finance or Billing Department Employee (Insider)	
		(2) Means *How would the actor do it? What would they do?*	The employee is not allowed to modify the bill amounts, status, amounts of refunds, or transaction records without authorization.	
		(3) Motive *What is the actor's reason for doing it?*	The employee may do this for personal financial gain, to help another person, or because of personal dissatisfaction with the hospital.	
		(4) Outcome *What would be the resulting effect on the information asset?*	❑ **Disclosure** ❑ **Destruction** ❑ **Modification** ❑ **Interruption**	
			Modification: Changing information without permission.	
		(5) Security Requirements *How would the information asset's security requirements be breached?*	There would be a lack of integrity in billing and payment because that information would be altered without proper authorization. The records would no longer be accurate.	
		(6) Probability *What is the likelihood that this threat scenario could occur?*	❑ **High** ❑ **Medium** ❑ **Low** **Medium – 50%:** The probability is considered medium because, as part of their duties, billing staff already use the billing system. The risk of making unauthorized changes can be mitigated, however,	

			through access controls, approvals, and activity logs.

(7) Consequences *What are the consequences to the organization or the information asset owner as a result of the outcome and breach of security requirements?*	(8) Severity *How severe are these consequences to the organization or asset owner by impact area?* *Assuming :* *0= No impact* *10=Highest impact*		
	Impact Area	**Value**	**Score**
If the wrong information is entered into billing or payment history, patients might end up paying the incorrect price. The hospital has to suffer the loss of money due to refunds or payments that are incorrect. It could also cause complaints from patients, loss of trust, and additional time needed to correct the records.	Reputation & Customer Confidence	7	3.5
	Financial	9	4.5
	Productivity	6	3.0
	Safety & Health	1	0.5
	Fines & Legal Penalties	6	3.0
	User Defined Impact Area	9	4.5
		Relative Risk Score	**19.0**

(9) Risk Mitigation

Based on the total score for this risk, what action will you take?

❑ **Accept**	❑ **Defer**	❑ **Mitigate**	❑ **Transfer**

Mitigate

For the risks that you decide to mitigate, perform the following:

On what container would you apply controls?	*What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?*
1. Staff User Accounts	Allow employees access only if it is necessary for their work. **Residual risk**: An employee could continue to use the access they already have.

2. Billing System	To track changes to billing information, maintain audit logs of persons making changes, what information is being changed, and the time at which the changes were made. **Residual risk:** Wrong changes may still occur before they are detected.
3. Billing and Refund Process	Require permission from another authorized staff member for large bill changes or refunds. **Residual risk:** Two employees could collaborate to make an unauthorized change.
4. Billing Database	Regularly back up billing and payment records so incorrect changes can be restored. **Residual risk:** In case the backup is not up to date, some recent changes might be lost.
5. Hospital Employees	Provide clear rules and training about how to use billing information and not making changes without permission. **Residual risk:** An employee may still ignore the rules on purpose.
6. Finance Office / Billing Computers	Allow only authorized staff to use billing computers and keep the finance area restricted. **Residual risk:** If an authorized employee is using the system, there is the potential for them to make unauthorized changes.

References

[1] Cybersecurity and Infrastructure Security Agency, “Secure Our World,” CISA. [Online]. Available: https://www.cisa.gov/cybersecurity-awareness-month

[2] National Institute of Standards and Technology, “Digital Identity Guidelines: Authentication and Authenticator Management,” NIST SP 800-63B. [Online]. Available: https://pages.nist.gov/800-63-4/sp800-63b.html

[3] National Institute of Standards and Technology, “Security and Privacy Controls for Information Systems and Organizations,” NIST SP 800-53 Rev. 5. [Online]. Available: https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

[4] Cybersecurity and Infrastructure Security Agency, “Insider Threat Mitigation Guide,” CISA. [Online]. Available: https://www.cisa.gov/sites/default/files/2022-11/Insider%20Threat%20Mitigation%20Guide_Final_508.pdf

[5] PCI Security Standards Council, “PCI Data Security Standard (PCI DSS).” [Online]. Available: https://www.pcisecuritystandards.org/standards/pci-dss/

Patient Medical Records (IT23824942)

Allegro worksheet 8

Allegro Worksheet 8	**Critical Information Asset Profile**	
(1) Critical Asset *What is the critical information asset?*	**(2) Rationale for Selection** *Why is this information asset important to the organization?*	**(3) Description** *What is the agreed-upon description of this information asset?*
Patient Medical Records (PMR) Classification: Highly confidential clinical information.	Essential for safe diagnosis, treatment and continuity of care. Disclosure harms privacy; inaccurate records may cause unsafe decisions; unavailability delays treatment in a 24-hour hospital.	Patient identifiers, medical history, diagnoses, allergies, laboratory/test results, prescriptions, treatments, doctors' notes and discharge summaries. Stored in the PMR database, attachments and backups are accessed via clinical workstations. Billing and employee records are excluded.
(4) Owner(s) *Who owns this information asset?*		
Information owner: Head of Medical Records, accountable for access approval, quality and risk decisions. Technical custodian: IT Manager, responsible for application, database, backups and access-control implementation. Clinical staff are authorized users, not technical owners.		
(5) Security Requirements *What are the security requirements for this information asset?*		
[x] Confidentiality	Only authorized personnel can view this information asset, as follows:	Treating doctors/nurses: relevant clinical records only. Records officers: necessary identification fields. IT support: approved, logged access only. Encrypt stored records/backups and use TLS for transmission.

[x] Integrity	Only authorized personnel can modify this information asset, as follows:	Clinical staff update only fields within their role. Record author, time and previous value for changes. Correct entries through traceable amendments; prevent silent deletion or alteration of allergies and prescriptions.
[x] Availability	This asset must be available for these personnel to do their jobs, as follows:	Authorized clinical staff need timely access for emergencies and routine care. Maintain tested recovery and controlled downtime records. Proposed recovery targets: RTO 4 hours RPO 1 hour, subject to clinical approval.
	This asset must be available for 24 hours/day, 7 days/week, 52 weeks/year. This is a service requirement, not a claim of zero downtime.	Continuous-service requirement; downtime procedures support care during an outage.
[x] Other	This asset has special regulatory compliance protection requirements, as follows:	Accountability and privacy: individual identities, traceable access, minimum necessary use, approved retention/disposal and applicable disclosure obligations. Compliance confirms jurisdiction and lawful handling requirements.

(6) Most Important Security Requirement

What is the most important security requirement for this information asset?

[ ] Confidentiality	[x] Integrity	[ ] Availability	[ ] Other

Patient Medical Records (IT23824942)

Allegro worksheet 10 – Risk 1

Allegro - Worksheet 10		Information Asset Risk Worksheet			
Information Asset Risk		Information Asset	Patient Medical Records (PMR) | PMR-R1		
		Area of Concern	An employee with a legitimate PMR account exports multiple records outside their care responsibilities and sells the information to an external party.		
	Threat	(1) Actor *Who would exploit the area of concern or threat?*	A malicious hospital employee with legitimate PMR access but excessive permissions.		
		(2) Means *How would the actor do it? What would they do?*	Broad roles permit searches and exports across unrelated patients. The employee downloads records and sends them through an unapproved external channel. Existing logs are not reviewed, delaying detection. Valid login credentials do not authorize this disclosure.		
		(3) Motive *What is the actor's reason for doing it?*	Deliberate financial gain from selling sensitive patient information.		
		(4) Outcome *What would be the resulting effect on the information asset?*	[x] Disclosure [ ] Modification	[ ] Destruction [ ] Interruption	
		(5) Security Requirements *How would the information asset's security requirements be breached?*	Confidentiality: records are viewed and disclosed without legitimate care or administrative purpose. Accountability is weakened by unreviewed access logs. No alteration or outage is assumed.		
		(6) Probability *What is the likelihood that this Threat scenario could occur?*	[ ] High 75%	[x] Medium 50%	[ ] Low 25%

	(7) Consequences *What are the consequences to the organization or the information asset owner because of the outcome and breach of security requirements?*	(8) Severity *How severe are these consequences to the organization or asset owner by impact area?*		
		Impact Area	**Value**	**Score**
Information Asset Risk	Reputation (9): Multi-patient clinical disclosure may cause lasting loss of trust. Financial (7): Investigation, patient support and lost custom create major costs statutory penalties are scored separately.	Reputation & Customer Confidence	9	4.5
		Financial	7	3.5
	Productivity (5): Records and IT staff divert time to investigation normal clinical work largely continues. Safety and health (4): Distress or reluctance to disclose clinical history is plausible, but direct treatment disruption is not assumed.	Productivity	5	2.5
		Safety & Health	4	2.0
	Fines/legal (6): Unauthorized disclosure may trigger material regulatory or legal consequences if applicable duties are breached. This is conditional, not a confirmed fine. Service disruption (3): Account restrictions cause limited, localized disruption PMR stays operational.	Fines & Legal Penalties	6	3.0
		Service Disruption (User Defined)	3	1.5
Relative Risk Score				17.0

(9) Risk Mitigation *Based on the total score for this risk, what action will you take?*			
[ ] Accept	[ ] Defer	[x] Mitigate	[ ] Transfer
For the risks that you decide to mitigate, perform the following:			
On what container would you apply controls?	*What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?*		

PMR application and identities	Technical and administrative: restrict by role and care assignment; approve exceptional access and review it next working day. Disable unnecessary bulk exports. Head of Medical Records approves access; IT implements it. Test with a user who should be denied unrelated records.
Audit log store and export channels	Technical: centralize protected logs and alert on unusual searches/exports. IT security reviews alerts daily and tests one simulated misuse case monthly. Monitor both approved accounts and data leaving the system; MFA alone cannot prevent a malicious authorized insider.
Database, backups and workstations	Technical and physical: encrypt storage and backups; use TLS for approved transfers; protect keys separately. Lock unattended screens and restrict removable media. Encryption protects stored/transmitted data but cannot prevent copying after an authorized decryption.
Personnel and clinical work areas	Administrative and physical: confidentiality training, signed obligations, prompt leaver access removal and quarterly access certification. Secure print collection and restrict visitor access to records areas. HR and Medical Records retain training/review evidence.
Affected account and incident evidence	Response/continuity: on detection, IT revokes the account and active sessions, preserves logs and identifies affected patients. Privacy lead assesses disclosure/notification duties. Clinical lead assigns legitimate access to other staff so care continues. Do not shut down all PMR access for an isolated account incident.
PMR service and remaining exposure	Recovery/residual risk: correct access rules, verify legitimate access and increase monitoring before closing the incident. Disclosed information cannot reliably be recalled. A user could still photograph a screen. Information owner may accept only the remaining monitored exposure after control tests; document approval and a quarterly review.

Patient Medical Records (IT23824942)

Allegro worksheet 10 – Risk 2

Allegro - Worksheet 10		Information Asset Risk Worksheet			
Information Asset Risk	Threat	Information Asset	Patient Medical Records (PMR) | PMR-R2		
		Area of Concern	A phishing-led ransomware intrusion encrypts the PMR database/attachments and reachable backup copies, preventing clinical access across the hospital.		
		(1) Actor *Who would exploit the area of concern or threat?*	An external cybercriminal an employee unintentionally enables initial access.		
		(2) Means *How would the actor do it? What would they do?*	A malicious attachment compromises a workstation. The attacker obtains a privileged credential from that compromised environment, then uses poorly restricted server access to encrypt PMR files and connected backups. Server-level access is required simply opening an email does not automatically encrypt the database.		
		(3) Motive *What is the actor's reason for doing it?*	Deliberate extortion by demanding payment to restore access.		
		(4) Outcome *What would be the resulting effect on the information asset?*	[ ] Disclosure [x] Modification	[ ] Destruction [x] Interruption	
		(5) Security Requirements *How would the information asset's security requirements be breached?*	Availability: authorized staff cannot retrieve records during treatment. Integrity: unauthorized encryption alters stored files. Confidentiality breach or permanent destruction is not assumed; investigation must check for theft and unrecoverable loss.		
		(6) Probability *What is the likelihood that this Threat scenario could occur?*	[ ] High 75%	[x] Medium 50%	[ ] Low 25%

	(7) Consequences *What are the consequences to the organization or the information asset owner because of the outcome and breach of security requirements?*	(8) Severity *How severe are these consequences to the organization or asset owner by impact area?*		
		Impact Area	**Value**	**Score**
Information Asset Risk	Reputation (8): A hospital-wide outage undermines confidence in reliable care. Financial (8): Forensics, rebuilding, overtime and cancelled services create major costs; ransom payment is not assumed.	Reputation & Customer Confidence	8	4.0
		Financial	8	4.0
	Productivity (9): Manual documentation and later reconciliation substantially reduce staff capacity. Safety and health (10): Unavailable allergy, medication and test information during emergencies creates credible potential for severe patient harm; harm is not asserted as certain.	Productivity	9	4.5
		Safety & Health	10	5.0
	Fines/legal (5): An outage and possible harm could trigger investigation or claims where duties were breached. Lower than R1 because disclosure is not established. Service disruption (10): Hospital-wide PMR interruption may delay emergency decisions, tests and treatment; this is broader than individual staff inefficiency.	Fines & Legal Penalties	5	2.5
		Service Disruption (User Defined)	10	5.0
Relative Risk Score				25.0

(9) Risk Mitigation *Based on the total score for this risk, what action will you take?*			
[ ] Accept	[ ] Defer	[x] Mitigate	[ ] Transfer
For the risks that you decide to mitigate, perform the following:			

On what container would you apply controls?	*What administrative, technical, and physical controls would you apply on this container? What residual risk would still be accepted by the organization?*
Email and staff workstations	Technical and administrative: filter risky attachments, patch endpoints and deploy endpoint detection. Train staff to report suspicious messages. IT and HR test detection/reporting with a safe simulation; measure reports and response time.
PMR servers and privileged accounts	Technical: allow only required application traffic, separate staff/server/backup networks and separate admin from everyday accounts. Use phishing-resistant MFA for remote/admin access. It verifies a normal workstation cannot reach backup management or server administration.
Backup repository and media	Technical and physical: maintain encrypted, offline or immutable copies with separate credentials and secure storage. Proposed one-hour protected recovery points support RPO; daily only copies do not. IT tests restoration monthly and key access during each test.
Affected devices and incident evidence	Response: isolate affected devices and server segments in coordination with clinical staff; preserve evidence, block compromised credentials and determine scope. Incident lead activates the clinical downtime plan immediately. Recovery follows verified containment, not merely disappearance of an alert.
Downtime paper records and clinical staff	Continuity: ward lead starts controlled, numbered paper forms with patient ID, timestamps and staff sign-off. Clinicians verify essential information from reliable available sources; escalate uncertain cases. Store forms securely; clinical management decides deferral/diversion if safe treatment cannot continue.
Clean PMR environment and remaining risk	Recovery: rebuild trusted systems, restore a verified clean point and have clinical staff validate patient IDs, allergies and medications before phased reopening. Reconcile paper records without silent overwriting. Accept only tested, bounded residual downtime/data gaps with clinical and information-owner approval.

Assessment Summary and Annexure

Risk prioritization

Order	Risk	Score	Action
1	PMR-R2: Ransomware	25.0	Mitigate first
2	PMR-R1: Insider disclosure	17.0	Mitigate

References

[1] R. A. Caralli, J. F. Stevens, L. R. Young, and W. R. Wilson, “Introducing OCTAVE Allegro: Improving the Information Security Risk Assessment Process,” Software Engineering Institute, Carnegie Mellon University, Tech. Rep. CMU/SEI-2007-TR-012, May 2007. [Online]. Available: https://doi.org/10.1184/R1/6574790.v1. [Accessed: Sep. 27, 2026].

[2] A. Nelson, S. Rekhi, M. Souppaya, and K. Scarfone, “Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile,” National Institute of Standards and Technology, NIST Special Publication 800-61 Rev. 3, Apr. 2025. doi: 10.6028/NIST.SP.800-61r3.

[3] U.S. Department of Health and Human Services, “Healthcare and Public Health Cybersecurity Performance Goals,” HHS Cyber Gateway. [Online]. Available: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html. [Accessed: Sep. 27, 2026].